SOKOINE UNIVERSITY OF AGRICULTURE

School of Engineering and Technology / College of Natural and Applied Sciences

Department of Informatics and Information Technology (DIIT)

BIT 111: MICROCOMPUTERS AND APPLICATIONS

TAKEHOME HOMEWORK ASSIGNMENT 6 (TOPIC 6)

Theme: DATA SECURITY, APPLIED CRYPTOGRAPHY, ENVIRONMENTAL PROTECTION & MALWARE DEFENSE

Course Instructor: Madam Bertha Msuliche Lebalwa (MSc)
Curriculum Coverage: Subtopic 6.1 (Physical & Environmental Protection), Subtopic 6.2 (Unauthorized Access & Cryptography), Subtopic 6.3 (Malware Classifications & Defense)
Assessment Weight: Coursework Component (Official Scheme: Assignments 5%, Tests 15%, Practical Report 10%, Practical Test 30%, UE 40% - subject to instructor review)
Submission Deadline: End of Week 12 by 17:00 EAT | Total Allocation: 100 Marks

INSTRUCTIONS TO CANDIDATES:
1. This assignment must be solved individually. Plagiarism, peer copying, or unreferenced AI generation will result in an automatic score of zero and disciplinary reporting under SUA Examination Regulations.
2. Answer ALL questions in Sections A, B, and C. Allocate your effort according to the mark allocations shown in brackets.
3. Support your explanations with clear examples, labeled diagrams, or command syntax where requested.
4. Use spreadsheet formulas only where requested in the spreadsheet assignment; no other numerical calculations are required.
5. Submit your completed work as a clean, stapled technical report or upload the single consolidated PDF to the SUA Virtual Learning Environment (Moodle) before the deadline.

SECTION A: FOUNDATIONAL SECURITY THEORIES [25 MARKS]

Question 1 [5 Marks]: Explain the CIA Triad (Confidentiality, Integrity, Availability) within the context of a University Academic Information System (such as the SUA SUASIS student records system). Provide one realistic operational threat that specifically compromises each of the three pillars.

Question 2 [5 Marks]: Differentiate between Symmetric and Asymmetric Cryptography across the following dimensions: (a) Key architecture, (b) Computational processing overhead, (c) Key distribution challenge, and (d) Primary operational use cases. Give one standardized cipher algorithm for each.

Question 3 [5 Marks]: Describe the properties of a Cryptographic Hash Function: (a) Deterministic output, (b) Pre-image resistance (one-way), (c) Second pre-image resistance, (d) Collision resistance, and (e) The Avalanche Effect. Why are MD5 and SHA-1 no longer accepted for cryptographic integrity verification?

Question 4 [5 Marks]: Differentiate between a Computer Virus, a Computer Worm, and a Trojan Horse. Focus on their respective mechanisms of infection, replication, and human interaction requirements.

Question 5 [5 Marks]: Explain the 3-2-1 Backup Strategy. Why does this rule specifically mandate that at least one copy of data be stored in an offsite or air-gapped physical location?

SECTION B: SECURITY CONCEPTS & RESPONSE [35 MARKS]

Question 6 [12 Marks]: Explain the purpose of an uninterruptible power supply (UPS) for a computer. Compare standby, line-interactive, and online UPS designs by describing how each responds to power interruptions or irregular supply. [12 Marks]

Question 7 [11 Marks]: Compare full, differential, and incremental backups in terms of what they copy and the general steps needed to restore files. Explain why an organization should keep an offline or offsite backup. [11 Marks]

Question 8 [12 Marks]: Applied Cryptographic Protocol Analysis: Hybrid Encryption & Digital Signatures:
(a) Explain how TLS/HTTPS implements 'Hybrid Cryptography' combining asymmetric RSA/ECC and symmetric AES-GCM during a secure web session. Why is asymmetric encryption used during handshake negotiation but discarded in favor of symmetric encryption for bulk payload data transmission? [5 Marks]
(b) A SUA professor digitally signs a final exam PDF using their private key. Trace the step-by-step mathematical verification process executed by the Examination Officer's software using the professor's public key. How does this prove both Authenticity and Non-Repudiation? [4 Marks]
(c) What is a Certificate Authority (CA), and what security catastrophe occurs if a root CA's private signing key is compromised? [3 Marks]

SECTION C: APPLIED MALWARE ANALYSIS & INCIDENT RESPONSE [40 MARKS]

Question 9 [15 Marks]: Ransomware Anatomy and Defense-in-Depth Architecture:
In May 2017, the WannaCry ransomware infected over 200,000 computers across 150 countries within hours, paralyzing critical hospital and enterprise networks.
(a) Analyze the propagation mechanism of WannaCry. How did it combine the EternalBlue exploit (targeting Microsoft SMBv1 vulnerability CVE-2017-0144) with worm-like autonomous network scanning to spread across microcomputers without human interaction? [6 Marks]
(b) Explain the technical encryption process executed by ransomware once inside a host machine (e.g., generation of local AES keys, encryption of user document extensions, and encryption of AES keys with the attacker's public RSA key). Why is it mathematically impossible to recover encrypted files without the attacker's private key in properly implemented ransomware? [5 Marks]
(c) Formulate a robust Defense-in-Depth strategy for SUA computer laboratories to prevent ransomware infections, addressing network segmentation, automated patch management, Endpoint Detection and Response (EDR), and immutable offline backups. [4 Marks]

Question 10 [15 Marks]: Modern Anti-Malware Detection Methodologies:
(a) Differentiate between Signature-Based Detection, Heuristic Analysis, and Behavioral Monitoring in modern anti-malware engines. Explain why signature-based detection fails against Zero-Day exploits and Polymorphic/Metamorphic malware. [6 Marks]
(b) What is a 'Sandbox' in anti-malware analysis? Describe how an Endpoint Detection and Response (EDR) agent detonates an unknown email executable attachment within an isolated virtual machine to detect malicious API calls and process injection. [5 Marks]
(c) Explain the concept of 'Living-off-the-Land' (LotL) attacks. Why are sophisticated adversaries increasingly utilizing native operating system binaries (such as PowerShell, WMI, and `certutil.exe`) rather than compiling custom malware executables? [4 Marks]

Question 11 [10 Marks]: NIST Incident Response Lifecycle Execution:
A laboratory technician at SUA detects that 15 desktop microcomputers in the Solomon Mahlangu Campus (SMC) computer lab are exhibiting anomalous high outbound network traffic to an unknown external IP address in Eastern Europe, and their fans are running at 100% speed.
(a) Classify this security incident (e.g., Botnet Command-and-Control / Cryptojacking). [2 Marks]
(b) Outline the tactical response steps according to the four phases of the NIST SP 800-61 Computer Security Incident Handling Guide: [8 Marks]
1. Containment: Immediate actions to isolate compromised hosts without destroying volatile memory forensic evidence.
2. Eradication: Identifying malware persistence mechanisms (scheduled tasks, registry run keys, services) and removing malicious artifacts.
3. Recovery: Re-imaging systems from known clean gold masters, restoring data from verified backups, and testing network connectivity.
4. Post-Incident Activity: Documenting root cause analysis and implementing preventative firewall controls.